

Juan Pablo de Legarreta

NETC 170 – IT Governance & Management

Module Five Assignment

Cybersecurity Regulations and Laws

We read about eight important regulations and laws in cybersecurity this week: HIPAA, FISMA, GLBA, PCI DSS, the SOX Act, NYDFS Cybersecurity Regulation, CISA, and CIRCIA. These regulations cover a wide array of industries, services, and protections. They all have required security controls and indicate how to ensure compliance. The table below shares a description, the required security controls, and the party responsible for ensuring compliance for these eight regulations and laws:

Cybersecurity Law/Regulation	Description	Required Security Controls	Who is responsible for ensuring compliance?
HIPAA (example)	Protects the privacy and security of health information	Administrative, physical and technical safeguards	HIPAA Privacy Officer, Security Officer, Compliance Officer, and IT Dept.
FISMA	Federal legislation defining framework of guidelines and security standards to protect government information and operations; applies to government agencies and organizations	Promotes Confidentiality, Integrity, and Availability of IT systems and data; requires continuous monitoring, annual security reviews, risk assessments, system security plans, meets NIST SP 800-53, FIPS 199	NIST responsible for developing standards and policies, compliance falls on heads of gov't agencies and departments, Office of the Inspector General
GLBA	A federal law controlling the ways financial institutions deal with the private information of individuals; also	Must give clear and conspicuous notice to consumers about how their data is collected, stored, and used; must give	Senior leadership in companies, IT management, boards of directors, and compliance officers employed

	modernized the financial industry and enhanced competition	written privacy policy notices to customers	by the financial institutions
PCI DSS	A security standard that applies to all merchants and service providers that process, transmit, or store cardholder data	Has 12 Requirements that cover Securing Networks, Protecting Cardholder data, Vulnerability Management, Access Control, Monitoring and Testing, and having Security Policies	Compliance is ensured through contracts between payment brands and merchants, banks, etc.; each merchant is responsible for being compliant
Sarbanes-Oxley Act	Regulations for auditing and financial reporting that apply to all public companies to protect shareholders and the public from accounting errors and fraudulent financial practices	Internal controls over financial reporting, data security policies, audits, and personal accountability	CEOs and CFOs are personally liable for the accuracy of financial reports, companies responsible for audits and implementing controls
New York Department of Financial Services (NYDFS) Cybersecurity Regulation	Requires banks, insurers, and financial services institutions licensed in New York to assess their cybersecurity risk profiles and promote protection of consumer data	Define a security program structure, have 2FA, designate a CISO, have written cybersecurity policies, perform an annual penetration test, and provide an annual certificate of compliance	NYDFS reviews compliance certificates, companies are each responsible for putting together their compliance certificates
Cybersecurity Information Sharing Act (CISA)	Allows US gov't agencies and non gov't entities to share information with each other to investigate cyberattacks	Sharing of data with CISA and other gov't agencies, strict protections and regulations on shared data and how gov't uses it	Department of Homeland Security, Cybersecurity and Infrastructure Security Agency, Private sector organizations

Cyber Incident Reporting for Critical Infrastructure Act of 2022	An Act requiring CISA to develop and implement regulations for covered entities to report covered cyber incidents and ransom payments	Regulations standardizing reporting deadlines (eg 72 hours), intergovernmental Cyber Incident Reporting Council, pilot program to identify systems with vulnerabilities and to notify owners, CISA-FBI joint Ransomware Task Force	CISA, Cyber Incident Reporting Council, and FBI joint Ransomware Task Force
--	--	---	--

Sources

CISA. “Cyber incident reporting for critical Infrastructure Act of 2022.” *CISA*, 2024, https://www.cisa.gov/sites/default/files/2023-01/CIRCIA_07.21.2022_Factsheet_FINAL_508%20c.pdf

CMS Cybergeek. “Federal Information Security Modernization Act (FISMA).” *Security.cms.gov*, 2024, <https://security.cms.gov/learn/federal-information-security-modernization-act-fisma>

IT Governance. “PCI DSS | What it is and How to Comply.” *IT Governance*, 2018, <https://www.itgovernance.co.uk/pci-dss>

Lutkevich, Ben. “Sarbanes-Oxley Act.” *TechTarget*, March 2023, <https://www.techtarget.com/searchcio/definition/Sarbanes-Oxley-Act>

PlasticSurgery.org. “HIPAA Basics.” *PlasticSurgery.org*, <https://www.plasticsurgery.org/documents/medical-professionals/health-policy/HIPAA/HIPAA-Basics.pdf>.

Rapid7. “The NYFDS Cybersecurity Regulation.” *Rapid7*, <https://www.rapid7.com/fundamentals/nydfs-cybersecurity-regulation/>

Terrell Hanna, Katie. “What is the Cybersecurity Information Sharing Act (CISA)?” *TechTarget*, July 2024, <https://www.techtarget.com/whatis/definition/Cybersecurity-Information-Sharing-Act-CISA>

Terrell Hannah, Katie and Garry Kranz. “What is the Gramm-Leach-Bliley Act?” *TechTarget*, January 2025, <https://www.techtarget.com/searchcio/definition/Gramm-Leach-Bliley-Act>